

Research Proposal – Creating a Machine-Readable SKOS Taxonomy of the NIST Cybersecurity Framework 2.0

Gheorghe Turca
University of Twente
Enschede, The Netherlands
g.turca@student.utwente.nl

Abstract

The NIST Cybersecurity Framework (CSF) 2.0 is a widely used framework for managing cybersecurity risk. It provides a taxonomy of high-level cybersecurity outcomes that helps organizations understand, assess, prioritize, and communicate their cybersecurity efforts [1]. However, the framework is primarily accessed through documents and reference tools that are not intended for machine-readable use.

This research proposes the development of a SKOS taxonomy of the NIST CSF 2.0. The taxonomy will be represented in RDF using SKOS. Functional validation will be performed through competency questions translated into SPARQL queries, while structural validation will be carried out using SHACL shapes. In addition, this research will investigate how the NIST CSF 2.0 taxonomy can be linked to an existing ISO/IEC 27001 SKOS taxonomy to enable cross-standard navigation between related cybersecurity concepts and controls.

Keywords: NIST Cybersecurity Framework 2.0, SKOS, RDF, Taxonomy, SPARQL, SHACL.

1 Introduction

The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity outcomes into a structured Core consisting of six high-level Functions: Govern, Identify, Protect, Detect, Respond, and Recover [1]. These Functions are further divided into Categories and Subcategories, which describe more specific cybersecurity outcomes.

Although the framework has a clearly defined internal structure, it is primarily accessed through official documents, reference tools, and exports through the CSF Reference Tool [3]. These formats support basic data reuse, but they do not provide a standardized semantic representation of the framework.

To overcome this limitation, Semantic Web technologies provide a suitable foundation for a machine-readable representation. RDF allows information to be represented as a graph, SKOS provides a lightweight vocabulary for modeling concepts, labels, hierarchies, and mappings, and SPARQL enables structured querying over RDF data [6, 5, 7]. Compared to more expressive ontology languages such as OWL, SKOS is particularly appropriate for representing taxonomies and classification schemes because it focuses on concept organization instead of complex logical axioms [5]. OWL-based approaches, while expressive, often intro-

duce significant modeling complexity and require consistent management, which can make them difficult to develop and maintain in practice [13]. Earlier work on security standards has also shown that OWL ontologies tend to be structurally rigid, incomplete, and hard to maintain, motivating the use of simpler vocabulary-based approaches such as SKOS [4].

A related approach has already been applied to ISO/IEC 27001:2022, where a SKOS taxonomy was developed to represent clauses, Annex A controls, ISO/IEC 27002 guidance, and ISO/IEC 27000 vocabulary terms [4]. That work demonstrated that a cybersecurity standard can be transformed into a queryable RDF/SKOS artifact and evaluated through competency questions and SPARQL queries. However, no equivalent, general-purpose SKOS representation currently exists for the NIST Cybersecurity Framework 2.0.

The goal of this research is to develop a validated SKOS taxonomy of the NIST CSF 2.0 and link it to related ISO/IEC 27001 concepts.

2 Problem Statement

Although the NIST CSF 2.0 has a clear conceptual structure, it cannot currently be directly queried, validated, or linked to other cybersecurity standards through a SKOS taxonomy.

This results in several limitations. For example, retrieving framework elements according to their hierarchy, checking whether a representation is structurally complete, or navigating from NIST CSF outcomes to related ISO/IEC 27001 controls requires additional interpretation.

The research problem is therefore that the conceptual organization of the NIST CSF 2.0 has not yet been represented as a validated SKOS taxonomy that supports semantic querying, structural validation, and cross linking.

2.1 Research Questions

The main research question is:

RQ: How can the NIST Cybersecurity Framework 2.0 be represented as a SKOS taxonomy to enable structured, machine-readable access, validation, and cross-standard linking?

This main question is answered through the following sub-research questions:

SRQ1: Which structural elements, relationships, and selected external references of the NIST CSF 2.0 should be represented in the SKOS taxonomy?

SRQ2: Does the resulting SKOS taxonomy provide correct answers to competency questions when queried with SPARQL?

SRQ3: How can the NIST CSF 2.0 taxonomy be linked to the existing ISO/IEC 27001 SKOS taxonomy to support cross-standard navigation?

3 Related Work

Research on machine-readable representations of cybersecurity standards has often focused on ontology-based modeling. Earlier work used ontological mapping to represent ISO/IEC 27001 for audit preparation and information security fortification [10], formalized information security knowledge using ontology-based methods [11], and applied ontologies to support information security compliance determination [12]. Related research also incorporated human-behavioral aspects into information security ontologies [16], evaluated ISO/IEC 27001 using ontology-based models [15], and argued for more integrated security ontologies based on a systematic review of existing proposals [19]. These studies show that semantic technologies can support structured access to security knowledge, but they mainly rely on ontology-based approaches that aim for wider conceptual modeling than is required for representing the internal structure of a framework such as NIST CSF 2.0.

A comparative study of ISO 27000-series ontologies found several limitations in earlier ontology-based approaches, including structural rigidity, incomplete coverage, and weak reproducibility [13]. These limitations motivate a lighter vocabulary-based approach.

The closest prior work is a SKOS taxonomy of ISO/IEC 27001:2022 [4]. That work formalized 307 concepts from the ISO 27000 family, including ISO/IEC 27001 clauses, 93 Annex A controls, ISO/IEC 27002 implementation guidance, and ISO/IEC 27000 vocabulary terms. The taxonomy was represented as a queryable SKOS schema and validated through 32 competency questions translated into SPARQL queries. It also included an interactive web application for exploring the taxonomy without requiring SPARQL expertise. This proposal follows a similar methodological direction, but applies it to the NIST Cybersecurity Framework 2.0 and extends the focus toward linking the resulting NIST CSF taxonomy to the existing ISO/IEC 27001 SKOS taxonomy.

For the transformation process, this research is informed by work on converting structured vocabularies to SKOS [14]. This is relevant because the NIST CSF 2.0 already has a clear hierarchical structure consisting of Functions, Categories, and Subcategories. The task is therefore to extract this existing structure and encode it in a standard machine-readable form.

For validation, this research uses competency questions. Competency questions are natural-language questions that define what an ontology or vocabulary should be able to answer [9]. More recent work has examined how competency questions can be formalized as SPARQL-OWL queries [17], and has provided datasets of competency questions with corresponding query translations [18]. In this proposal, competency questions are used as functional tests for the NIST CSF 2.0 taxonomy and are translated into SPARQL queries

to evaluate whether the taxonomy supports the intended retrieval and navigation tasks, while SHACL is used for structural validation [8].

4 Methodology

4.1 Answering SRQ1: Extracting and Representing NIST CSF 2.0

The first step is to extract the structure of the NIST CSF 2.0 Core from official NIST material, prioritizing the Reference Tool and other structured exports where available, and checking the extracted data against the CSF 2.0 specification [3, 2, 1]. The extraction scope is limited to explicit structural elements of the Core: Functions, Categories, Subcategories, identifiers, labels, descriptions, and selected Informative References that support later mapping.

The output of this phase will be a structured intermediate representation, such as a spreadsheet or JSON file, that records the extracted elements and their relationships. This intermediate representation will make the transformation process easier to inspect and reproduce.

4.2 Structural Validation with SHACL

Before functional evaluation, the taxonomy will be validated structurally with SHACL [8]. The SHACL shapes will check whether every concept has a preferred English label and a notation, whether every concept belongs to the NIST CSF concept scheme, whether each Category has a broader Function and each Subcategory a broader Category, whether each Subcategory includes a definition or description, whether duplicate notations occur within the concept scheme, and whether mapping properties point to valid external concepts.

4.3 Answering SRQ2: Functional Validation with SPARQL

SRQ2 is evaluated through competency questions translated into SPARQL queries. Each question will be translated into a SPARQL query and executed against the RDF taxonomy. The results will then be compared with the expected answers derived from the official NIST CSF 2.0 source material [1, 3].

4.4 Answering SRQ3: Linking to the ISO/IEC 27001 SKOS Taxonomy

SRQ3 is addressed by creating a set of links between the NIST CSF 2.0 taxonomy and the existing ISO/IEC 27001 SKOS taxonomy. Candidate mappings will be identified by comparing labels, descriptions, and selected Informative References, after which they will be checked to ensure that the relationship is meaningful and not based only on similar wording.

4.5 Website Development

A web-based interface will be developed to support browsing of the NIST CSF hierarchy, inspection of concept labels

and descriptions, and navigation to related ISO/IEC 27001 concepts where mappings are available.

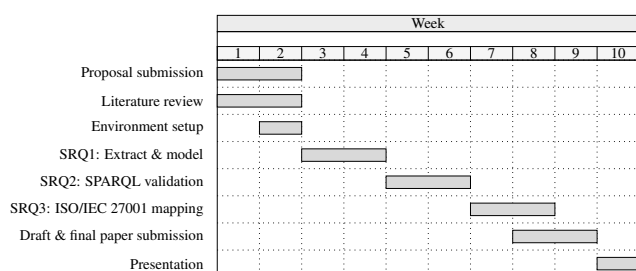
5 Expected Results

The expected outputs of this research are a SKOS taxonomy of the NIST CSF 2.0, a structured extraction file documenting the extracted framework elements and relationships, SHACL shapes for structural validation, a set of competency questions with corresponding SPARQL queries for functional evaluation, an initial mapping to the existing ISO/IEC 27001 SKOS taxonomy to support cross-standard navigation, and a website for browsing the taxonomy and its links to ISO/IEC 27001.

6 Planning

The project is scheduled across ten weeks, as shown in Figure 1.

Figure 1: Research project planning.



References

- [1] National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. NIST Cybersecurity White Paper 29, February 2024. <https://doi.org/10.6028/NIST.CSWP.29>
- [2] National Institute of Standards and Technology. *Introducing the NIST Cybersecurity Framework 2.0 Reference Tool!*. Computer Security Resource Center, August 2023. <https://csrc.nist.gov/News/2023/just-released-nist-csf-2-0-reference-tool>
- [3] National Institute of Standards and Technology. *NIST Cybersecurity Framework 2.0 Reference Tool*. NIST Computer Security Resource Center, 2024.
- [4] I. Donos. *Building a Machine-Readable SKOS Taxonomy of ISO/IEC 27001:2022*. University of Twente, 2026.
- [5] A. Miles and S. Bechhofer. *SKOS Simple Knowledge Organization System Reference*. W3C Recommendation, 18 August 2009. <https://www.w3.org/TR/skos-reference/>
- [6] R. Cyganiak, D. Wood, and M. Lanthaler. *RDF 1.1 Concepts and Abstract Syntax*. W3C Recommendation, 25 February 2014. <https://www.w3.org/TR/rdf11-concepts/>
- [7] S. Harris and A. Seaborne. *SPARQL 1.1 Query Language*. W3C Recommendation, 21 March 2013. <https://www.w3.org/TR/sparql11-query/>
- [8] H. Knublauch and D. Kontokostas. *Shapes Constraint Language (SHACL)*. W3C Recommendation, 20 July 2017. <https://www.w3.org/TR/shacl/>
- [9] M. Grüninger and M. S. Fox. The role of competency questions in enterprise engineering. In *Benchmarking – Theory and Practice*, pp. 22–31. Springer, 1995. https://doi.org/10.1007/978-0-387-34847-6_3
- [10] S. Fenz, G. Goluch, A. Ekelhart, B. Riedl, and E. Weippl. Information security fortification by ontological mapping of the ISO/IEC 27001 standard. In *Proceedings of the 13th Pacific Rim International Symposium on Dependable Computing*, pp. 381–388. IEEE, 2007. <https://doi.org/10.1109/PRDC.2007.29>
- [11] S. Fenz and A. Ekelhart. Formalizing information security knowledge. In *Proceedings of the 4th International Symposium on Information, Computer, and Communications Security*, pp. 183–194. ACM, 2009. <https://doi.org/10.1145/1533057.1533084>
- [12] S. Fenz, S. Plieschnegger, and H. Hobel. Ontology-based information security compliance determination. *Information & Computer Security*, 24(5):552–567, 2016. <https://doi.org/10.1108/ICS-07-2015-0030>
- [13] I. Meriah and L. Ben Arfa Rabai. Comparative study of ontologies based ISO 27000 series security standards. *Procedia Computer Science*, 160:85–92, 2019. <https://doi.org/10.1016/j.procs.2019.09.447>
- [14] M. van Assem, V. Malaise, A. Miles, and G. Schreiber. A method to convert thesauri to SKOS. In *The Semantic Web: Research and Applications*, LNCS 4011, pp. 95–109. Springer, 2006. https://doi.org/10.1007/11762256_10
- [15] D. Milicevic and M. Goeken. Ontology-based evaluation of ISO 27001. In *Conference on e-Business, e-Services and e-Society (I3E)*, pp. 93–102. Springer, 2010. https://doi.org/10.1007/978-3-642-16283-1_13
- [16] S. E. Parkin, A. van Moorsel, R. Coles, and R. Sharp. An information security ontology incorporating human-behavioural implications. In *Proceedings of the 2nd International Conference on Security of Information and Networks*, pp. 46–55. ACM, 2009. <https://doi.org/10.1145/1626195.1626209>

- [17] D. Wiśniewski, J. Potoniec, A. Ławrynowicz, and C. M. Keet. Analysis of ontology competency questions and their formalizations in SPARQL-OWL. *Journal of Web Semantics*, 59:100534, 2019. <https://doi.org/10.1016/j.websem.2019.100534>
- [18] J. Potoniec, D. Wiśniewski, A. Ławrynowicz, and C. M. Keet. Dataset of ontology competency questions to SPARQL-OWL queries translations. *Data in Brief*, 29:105098, 2020. <https://doi.org/10.1016/j.dib.2019.105098>
- [19] C. Blanco, J. Lasheras, E. Fernández-Medina, R. Valencia-García, and A. Toval. Basis for an integrated security ontology. *Computer Standards & Interfaces*, 33(4):372–388, 2011. <https://doi.org/10.1016/j.csi.2010.08.002>